

TRABAJO DE PROYECTO DE TELECOMUNICACIONES

Gerencia, Operación y Planificación de la Seguridad de la información

DOCENTE:

ING. ZHUMA MERA EMILIO RODRIGO

Integrantes:

GRACIA GUATO FELIX RAFAEL

MORALES COBEÑA MIYAKO KUSHIRO

MUÑOZ RICAURTE KARELYS THAIS

PINCAY MURILLO JOHN DANIEL

ZARSOZA VERA KELLY MELISSA

Contenido

INFORME EJECUTIVO DE GESTIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN A NIVEL DE BANCA ELECTRÓNICA	3
1. OBJETIVO DEL INFORME	3
2. RESUMEN GENERAL DE RIESGOS	3
3. PRINCIPALES RIESGOS IDENTIFICADOS	3
4. PLANES DE ACCIÓN PRIORITARIOS	3
RIESGO 1: ACCESO NO AUTORIZADO A SISTEMAS BANCARIOS MÓVILES.	3
RIESGO 2: ATAQUES DE PHISHING DIRIGIDOS A USUARIOS BANCARIOS.	4
RIESGO 3: VULNERABILIDAD EN LA APP MÓVIL.	5
RIESGO 4: PÉRDIDA DE DISPOSITIVOS MÓVILES CON INFORMACIÓN CRÍTICA.	6
RIESGO 5: INSEGURIDAD EN LA RED DE COMUNICACIÓN.	7
RIESGO 6: FUGAS DE INFORMACIÓN POR ERRORES HUMANOS.	8
RIESGO 7: CAÍDAS EN EL SERVICIO DE LA APP MÓVIL.	9
RIESGO 8: ERRORES EN LA AUTENTICACIÓN MULTIFACTOR.	10
RIESGO 9: PROBLEMAS CON LA ACTUALIZACIÓN DE LA APLICACIÓN.	11
RIESGO 10: SOBRECARGA DE TRÁFICO EN LA APP MÓVIL.	12
RIESGO 11: PROBLEMAS CON LA CONECTIVIDAD DE RED.	12
RIESGO 12: INCUMPLIMIENTO DE NORMATIVAS LEGALES.	13
5. NIVEL DE RIESGO ACTUAL	14
6. SOLICITUDES AL DIRECTORIO	15
7. CONCLUSIÓN	15
8. RECOMENDACIONES	15

INFORME EJECUTIVO DE GESTIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN A NIVEL DE BANCA ELECTRÓNICA

1. OBJETIVO DEL INFORME

El objetivo de este informe es presentar un análisis detallado de los riesgos asociados con la seguridad de la información en el entorno de la banca móvil del banco. A través de la matriz de riesgos, se identificaron los principales riesgos que afectan tanto a la infraestructura tecnológica como a las operaciones del banco. Este informe tiene como propósito informar sobre la situación actual de la seguridad de la información, los riesgos críticos identificados, y los planes de acción propuestos para mitigar dichos riesgos, asegurando el cumplimiento de las normativas vigentes, como la ISO 27001 y la LOPDP.

2. RESUMEN GENERAL DE RIESGOS

En total, se identificaron 12 riesgos clave que afectan la seguridad de la información en el banco, los cuales se distribuyen en diferentes categorías, tales como accesos no autorizados, ataques de phishing, vulnerabilidades en la aplicación móvil, pérdida de dispositivos móviles, e inseguridad en la red de comunicación. Cada riesgo tiene un impacto directo sobre la confidencialidad, integridad y disponibilidad de los datos y servicios, lo que puede resultar en pérdidas financieras, sanciones legales, y daño a la reputación del banco. A través de la matriz de riesgos, se ha establecido una clasificación de los riesgos según su gravedad, permitiendo priorizar las acciones correctivas y mitigar los impactos.

3. PRINCIPALES RIESGOS IDENTIFICADOS

Los riesgos más críticos identificados en la matriz incluyen el acceso no autorizado a los sistemas bancarios móviles, el phishing dirigido a usuarios bancarios, y vulnerabilidades en la app móvil. Estos riesgos pueden llevar a la pérdida de fondos y datos confidenciales, lo que podría afectar la confianza de los clientes y la reputación del banco. Otros riesgos como la pérdida de dispositivos móviles con información crítica, la inseguridad en la red de comunicación, y los errores humanos en la gestión de la seguridad interna también son relevantes y requieren atención inmediata. Cada uno de estos riesgos tiene un plan de mitigación específico que debe implementarse para reducir su probabilidad de ocurrencia.

4. PLANES DE ACCIÓN PRIORITARIOS

RIESGO 1: ACCESO NO AUTORIZADO A SISTEMAS BANCARIOS MÓVILES.

Plan de Mitigación:

- Implementar autenticación multifactor (MFA).
- Activar registro y monitoreo de accesos y actividades sospechosas.

Meta de Cumplimiento:

Alcanzar el 80% de cobertura en los primeros 6 meses.

Actividades:

Para abordar el riesgo de accesos no autorizados a nuestros sistemas críticos, implementaremos un plan integral que combina autenticación multifactor (MFA) y sistemas avanzados de monitoreo. Durante los próximos seis meses, trabajaremos en tres fases clave: iniciando con la identificación y priorización de sistemas críticos en los primeros dos meses (30% de avance), implementando soluciones técnicas centrales en los meses 3-4 (50% de avance), y culminando con la expansión y optimización en los últimos dos meses para alcanzar el 80% de cobertura.

El plan contempla la implementación gradual de MFA en el 80% de los sistemas críticos, utilizando herramientas como Microsoft Authenticator, junto con la configuración de sistemas SIEM (como Splunk) para el monitoreo continuo de actividades sospechosas.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Identificar sistemas críticos y usuarios que acceden.	Lista priorizada para MFA y monitoreo.
2	Seleccionar e implementar la solución de MFA y herramientas de monitoreo.	Herramienta MFA funcional y piloto inicial.
3	Activar MFA en usuarios de alto riesgo (TI, Finanzas, Gerencia) y configurar alertas básicas de accesos.	30% de usuarios críticos protegidos.
4	Extender MFA a usuarios operativos + ajustar monitoreo de accesos.	60% de usuarios protegidos.
5	Refuerzo de políticas y capacitación de usuarios. Activación de monitoreo en todos los sistemas prioritarios.	75% de usuarios y sistemas monitoreados.
6	Activar MFA y monitoreo en usuarios faltantes + validación de cumplimiento.	80% de cobertura total en sistemas críticos.

RIESGO 2: ATAQUES DE PHISHING DIRIGIDOS A USUARIOS BANCARIOS.

Plan de Mitigación:

- Implementar campañas periódicas de concientización sobre phishing.
- Mejorar programas de capacitación y simulacros de phishing.

Meta de Cumplimiento:

Alcanzar el 75% de cobertura en los primeros 3 meses.

Actividades:

Para abordar el riesgo de ataques de phishing dirigidos a los usuarios bancarios, implementaremos un programa integral de concientización y capacitación continua. Durante los primeros tres meses, desarrollaremos un plan en tres fases: en los primeros dos meses, nos enfocaremos en la creación de contenido educativo y la planificación de simulacros (50% de avance), luego ejecutaremos las primeras campañas de capacitación en el mes 3 (75% de avance). En el siguiente trimestre, reforzaremos los programas existentes y expandiremos la capacitación a más empleados y clientes.

Este enfoque permitirá reducir la probabilidad de éxito de los ataques de phishing y mejorar la respuesta ante intentos de fraude.

Tabla de actividades

<i>Mes</i>	<i>Acción puntual</i>	<i>Resultado esperado</i>
1	Diseñar y planificar contenido de capacitación sobre phishing y seguridad.	Desarrollo del material educativo para capacitación.
2	Planificar y probar simulacros de phishing internos.	Simulacro ejecutado y retroalimentación recibida.
3	Realizar la primera campaña de concientización para empleados y usuarios.	30% de empleados capacitados y pruebas de phishing iniciales.
4	Extender las campañas de concientización y evaluar resultados.	50% de empleados capacitados, retroalimentación obtenida.
5	Reforzar las políticas de seguridad y continuar con simulacros periódicos.	65% de empleados capacitados, campañas extendidas.
6	Implementar nuevos simulacros y actualizar los materiales educativos.	75% de cobertura total en usuarios bancarios capacitados.

RIESGO 3: VULNERABILIDAD EN LA APP MÓVIL.

Plan de Mitigación:

- Implementar pruebas de penetración continuas.
- Realizar auditorías de seguridad periódicas.

Meta de Cumplimiento:

Alcanzar el 85% de cobertura en los primeros 6 meses.

Actividades:

Para abordar el riesgo de vulnerabilidades en la app móvil, implementaremos un plan que se enfoca en la realización de pruebas de penetración continuas y auditorías de seguridad. Durante los primeros tres meses, comenzaremos con la planificación y selección de herramientas de prueba (30% de avance), en los meses 3-4 implementaremos las pruebas iniciales y auditorías internas (50% de avance), y en los últimos meses, trabajaremos en la mejora continua de las pruebas y la corrección de vulnerabilidades encontradas, alcanzando el 85% de cobertura. Este enfoque permitirá identificar y corregir de manera proactiva las vulnerabilidades en la aplicación móvil antes de que sean explotadas.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Planificación de pruebas de penetración y auditorías. Selección de herramientas y definición de áreas críticas de la app.	Herramientas de prueba seleccionadas y plan de auditoría definido.
2	Implementación de pruebas de penetración y auditoría inicial.	Realización de pruebas y auditorías con informe de vulnerabilidades.
3	Análisis de resultados y corrección de vulnerabilidades más críticas.	30% de vulnerabilidades corregidas.
4	Implementación de pruebas adicionales y auditorías externas.	50% de vulnerabilidades corregidas, pruebas adicionales realizadas.
5	Optimización de las pruebas y auditorías, implementación de parches regulares.	70% de vulnerabilidades corregidas.
6	Validación final de corrección de vulnerabilidades, optimización continua de pruebas.	85% de cobertura total en la app móvil, vulnerabilidades corregidas.

RIESGO 4: PÉRDIDA DE DISPOSITIVOS MÓVILES CON INFORMACIÓN CRÍTICA.

Plan de Mitigación:

- Implementar políticas de gestión de dispositivos móviles.
- Activar bloqueo remoto y cifrado de dispositivos móviles.

Meta de Cumplimiento:

Alcanzar el 90% de cobertura en los primeros 6 meses.

Actividades:

Para mitigar el riesgo de pérdida de dispositivos móviles con información crítica, implementaremos un plan que incluye cifrado completo de los dispositivos móviles y el bloqueo remoto de dispositivos perdidos o robados. Durante los primeros tres meses, se llevará a cabo un proceso de identificación y clasificación de dispositivos (30% de avance), seguido de la implementación de políticas de cifrado y control de acceso en los siguientes tres meses (50% de avance). En el último trimestre, optimizaremos la implementación y escalaremos la cobertura de protección a todos los dispositivos móviles del banco, alcanzando el 90% de cobertura. Estas medidas ayudarán a reducir la exposición a los riesgos de accesos no autorizados a cuentas bancarias y robo de datos sensibles en dispositivos móviles.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Identificar y clasificar los dispositivos móviles críticos.	Lista de dispositivos móviles prioritarios.
2	Implementar políticas de cifrado y acceso controlado.	30% de dispositivos cifrados y protegidos.
3	Activar políticas de bloqueo remoto y cifrado en dispositivos.	50% de dispositivos protegidos con cifrado y bloqueo remoto.
4	Extender la cobertura de protección a más dispositivos.	70% de dispositivos móviles protegidos.
5	Reforzar las políticas de seguridad y asegurar el cumplimiento.	85% de dispositivos móviles con cifrado y bloqueo remoto.
6	Validación final de cumplimiento y optimización continua.	90% de cobertura total en dispositivos móviles críticos.

RIESGO 5: INSEGURIDAD EN LA RED DE COMUNICACIÓN.

Plan de Mitigación:

- Implementar HTTPS y cifrado SSL en todas las conexiones.
- Reforzar la seguridad de la red e implementar protocolos seguros de comunicación.

Meta de Cumplimiento:

Alcanzar el 95% de cobertura en los primeros 6 meses.

Actividades:

Para mitigar el riesgo de inseguridad en la red de comunicación, implementaremos protocolos HTTPS y cifrado SSL en todas las transacciones y comunicaciones del banco. Durante los primeros tres meses, nos enfocaremos en la identificación de conexiones no seguras y la actualización de las infraestructuras críticas (30% de avance). En los meses 3-4, implementaremos la configuración de HTTPS y la optimización de protocolos de comunicación en los sistemas más críticos (50% de avance), y en los meses 5-6, aseguraremos que todos los sistemas estén protegidos, alcanzando el 95% de cobertura. Además, se proporcionará capacitación continua al personal sobre la implementación y el uso seguro de estas tecnologías.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Identificar sistemas y conexiones inseguras (HTTP) en la infraestructura del banco.	Informe de sistemas no protegidos.
2	Seleccionar herramientas para la implementación de HTTPS y configuración de SSL.	Herramientas seleccionadas y configuradas para pruebas.
3	Implementar HTTPS en los sistemas más críticos y realizar pruebas de seguridad.	30% de sistemas actualizados a HTTPS.
4	Ampliar la cobertura de HTTPS a todos los sistemas operativos y servidores.	50% de sistemas protegidos con HTTPS y SSL.
5	Reforzar políticas de seguridad en la red y asegurar el cifrado SSL en todos los sistemas.	75% de la infraestructura protegida y monitoreada.
6	Validación final de seguridad de red y optimización continua.	95% de cobertura total en la red bancaria con protocolos seguros.

RIESGO 6: FUGAS DE INFORMACIÓN POR ERRORES HUMANOS.

Plan de Mitigación:

- Implementar formación continua y auditorías internas periódicas.
- Desarrollar un plan de capacitación continua en seguridad de la información.

Meta de Cumplimiento:

Alcanzar el 85% de cobertura en los primeros 3 meses.

Actividades:

Para abordar el riesgo de fugas de información por errores humanos, implementaremos un programa de capacitación continua y auditorías internas periódicas. Durante los primeros tres meses, se dará prioridad a la identificación de las brechas en las competencias de los empleados (30% de avance), luego implementaremos un programa de capacitación que abarque a todos los empleados de la banca electrónica (50% de avance). En el siguiente trimestre, reforzaremos los programas de formación con auditorías periódicas, alcanzando el 85% de cobertura en los primeros tres meses. Esto permitirá reducir significativamente los errores operativos que pueden llevar a la exposición de datos sensibles de los clientes.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Identificar las áreas con brechas de conocimiento en seguridad de la información.	Informe de brechas en habilidades y áreas prioritarias de capacitación.
2	Implementar programa de capacitación sobre protección de datos y manejo de información sensible.	30% de personal capacitado en seguridad y manejo de información.
3	Realizar simulacros internos y auditorías periódicas sobre seguridad de la información.	50% de personal capacitado y pruebas de simulacro realizadas.
4	Reforzar políticas internas de seguridad y continuar con los simulacros.	70% de personal capacitado y auditorías completas.
5	Evaluar el cumplimiento de las políticas y expandir el programa de capacitación a nuevos empleados.	80% de personal capacitado y políticas reforzadas.
6	Validación de cumplimiento y ajustes finales a las auditorías internas.	85% de cobertura total en capacitación de seguridad.

RIESGO 7: CAÍDAS EN EL SERVICIO DE LA APP MÓVIL.

Plan de Mitigación:

- Implementar infraestructura en la nube y realizar pruebas de resiliencia.
- Configurar servicios de cloud computing escalables.

Meta de Cumplimiento:

Alcanzar el 90% de cobertura en los primeros 6 meses.

Actividades:

Para mitigar el riesgo de caídas en el servicio de la app móvil debido a falta de disponibilidad y capacidad de los servidores, implementaremos infraestructura escalable en la nube. Durante los primeros tres meses, nos enfocaremos en evaluar los servicios actuales y planificar la transición a la nube (30% de avance). En los meses 3-4, implementaremos los servicios de cloud computing escalables y realizaremos pruebas de resiliencia (50% de avance). En los meses 5-6, nos enfocaremos en la optimización de la infraestructura y la validación de su efectividad, alcanzando el 90% de cobertura en los sistemas críticos de la app móvil. Estas medidas garantizarán la disponibilidad continua del servicio y la capacidad de manejar picos de tráfico.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Evaluar los servidores actuales y planificar la migración a la nube.	Informe de evaluación y planificación de infraestructura.
2	Seleccionar proveedor de servicios en la nube y definir requisitos de escalabilidad.	Acuerdo con proveedor de nube y configuración de requisitos.
3	Implementar la infraestructura en la nube y configurar servicios escalables.	30% de la infraestructura migrada a la nube.
4	Realizar pruebas de resiliencia en la infraestructura en la nube.	50% de la infraestructura en la nube probada y ajustada.
5	Optimizar la infraestructura y realizar pruebas de carga.	75% de infraestructura optimizada y preparada para carga máxima.
6	Validación final de la infraestructura escalable y análisis de efectividad.	90% de cobertura total con infraestructura escalable en la nube.

RIESGO 8: ERRORES EN LA AUTENTICACIÓN MULTIFACTOR.

Plan de Mitigación:

- Revisar y reforzar el proceso de autenticación multifactor (MFA).

Realizar una revisión continua de los sistemas MFA.

Meta de Cumplimiento:

Alcanzar el 90% de cobertura en los primeros 6 meses.

Actividades:

Para abordar el riesgo de errores en la autenticación multifactor (MFA), implementaremos un plan que se enfoca en revisar y reforzar el proceso de MFA. Durante los primeros tres meses, realizaremos una revisión exhaustiva de los sistemas de MFA existentes y evaluaremos las posibles fallas en el proceso de verificación (30% de avance). En los meses 3-4, trabajaremos en la optimización y fortalecimiento de los procesos de MFA, incluyendo la actualización de las herramientas y la mejora de la experiencia del usuario (50% de avance). En los últimos meses, realizaremos una validación y monitoreo de los sistemas MFA implementados, asegurando que todos los accesos sean correctos y seguros, alcanzando el 90% de cobertura en los sistemas críticos.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Revisar el proceso de autenticación multifactor y evaluar las fallas de verificación.	Informe de evaluación de MFA.
2	Optimizar la infraestructura y la tecnología de MFA en los sistemas más críticos.	30% de procesos MFA optimizados.
3	Implementar una revisión de seguridad de MFA y reforzar las configuraciones.	50% de sistemas con MFA revisados y reforzados.
4	Extender la cobertura de MFA a otros sistemas y usuarios críticos.	70% de sistemas críticos protegidos con MFA.

5	Realizar pruebas de carga y análisis de rendimiento de MFA.	80% de sistemas con MFA optimizado y pruebas completadas.
6	Validación final del cumplimiento y ajuste de sistemas MFA.	90% de cobertura total en MFA y verificación continua.

RIESGO 9: PROBLEMAS CON LA ACTUALIZACIÓN DE LA APLICACIÓN.

Plan de Mitigación:

- Implementar un sistema de gestión de parches y versiones.
- Realizar pruebas de compatibilidad en todas las versiones.

Meta de Cumplimiento:

- Alcanzar el **80% de cobertura** en los primeros **6 meses**.

Actividades:

Para mitigar el riesgo de problemas con la actualización de la aplicación, implementaremos un sistema de gestión de parches y versiones que permita actualizar el software de manera eficiente y sin interrumpir el servicio. Durante los primeros tres meses, realizaremos un análisis de las versiones actuales y las actualizaciones pendientes (30% de avance). En los meses 3-4, implementaremos un sistema de gestión de parches que garantice que todas las versiones estén actualizadas y sean compatibles (50% de avance). En los últimos dos meses, nos enfocaremos en realizar pruebas de compatibilidad para asegurar que las actualizaciones no causen problemas operativos, alcanzando el 80% de cobertura en los primeros 6 meses.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Analizar las versiones actuales de la aplicación y las actualizaciones pendientes.	Informe de versiones y parches pendientes.
2	Implementar un sistema de gestión de parches y versiones.	Sistema de gestión de parches operativo.
3	Realizar pruebas de compatibilidad en versiones anteriores y actuales.	30% de las versiones probadas y optimizadas.
4	Aplicar parches y actualizar sistemas operativos a las versiones más recientes.	50% de las versiones y parches aplicados.
5	Optimizar el sistema de gestión de parches y realizar pruebas finales.	75% de sistemas actualizados y testeados.
6	Validación final y ajuste de las actualizaciones, con seguimiento continuo.	80% de cobertura total en las actualizaciones y pruebas.

RIESGO 10: SOBRECARGA DE TRÁFICO EN LA APP MÓVIL.

Plan de Mitigación:

- Optimización de los servidores y balanceo de carga.
- Invertir en la optimización de la red y escalabilidad.

Meta de Cumplimiento:

Alcanzar el 85% de cobertura en los primeros 3 meses.

Actividades:

Para mitigar el riesgo de sobrecarga de tráfico en la app móvil, implementaremos medidas para optimizar los servidores y configurar un balanceo de carga adecuado. Durante los primeros tres meses, realizaremos un análisis exhaustivo de la infraestructura actual y el tráfico de datos (30% de avance). En los meses 3-4, implementaremos nuevas herramientas de balanceo de carga y optimización de servidores (50% de avance), y en los últimos meses, realizaremos pruebas de escalabilidad y rendimiento para asegurar que la infraestructura pueda manejar picos de tráfico sin afectar el desempeño de la aplicación, alcanzando el 85% de cobertura.

Tabla de actividades

<i>Mes</i>	<i>Acción puntual</i>	<i>Resultado esperado</i>
1	Analizar la infraestructura actual de servidores y la capacidad de manejo de tráfico.	Informe sobre la capacidad de servidores y tráfico existente.
2	Implementar balanceo de carga en los servidores y optimizar los recursos.	30% de los servidores optimizados con balanceo de carga.
3	Optimizar la red y realizar pruebas de carga en los servidores.	50% de optimización realizada y pruebas de carga completas.
4	Ampliar la infraestructura para manejar altos volúmenes de tráfico.	70% de la infraestructura optimizada y escalada.
5	Realizar pruebas de rendimiento y validación de la capacidad de manejo de tráfico.	80% de infraestructura probada y optimizada.
6	Validación final de la infraestructura optimizada y ajustes finales.	85% de cobertura total en la infraestructura optimizada y escalada.

RIESGO 11: PROBLEMAS CON LA CONECTIVIDAD DE RED.

Plan de Mitigación:

- Establecer redes redundantes y mejorar las conexiones.
- Invertir en infraestructura de red de alta disponibilidad.

Meta de Cumplimiento:

Alcanzar el 90% de cobertura en los primeros 3 meses.

Actividades:

Para mitigar el riesgo de problemas con la conectividad de red, implementaremos redes redundantes que aseguren la disponibilidad continua de los servicios bancarios. Durante los primeros tres meses, nos enfocaremos en identificar las áreas críticas de la infraestructura y definir las especificaciones necesarias para la implementación de redes redundantes (30% de avance). En los meses 3-4, instalaremos infraestructura de red adicional para garantizar la alta disponibilidad de los servicios (50% de avance). En los meses 5-6, validaremos la efectividad de la red redundante y realizaremos pruebas de resistencia, alcanzando el 90% de cobertura.

Tabla de actividades

<i>Mes</i>	<i>Acción puntual</i>	<i>Resultado esperado</i>
1	Identificar áreas críticas y analizar la infraestructura de red actual.	Informe sobre la infraestructura y las conexiones críticas.
2	Seleccionar los componentes y proveedores necesarios para la infraestructura redundante.	Acuerdo con proveedores y planificación de la infraestructura.
3	Implementar redes redundantes y realizar las primeras pruebas de conectividad.	30% de la infraestructura redundante instalada.
4	Ampliar la cobertura de redes redundantes y asegurar la alta disponibilidad.	50% de la infraestructura de red instalada y funcional.
5	Validar la efectividad de la infraestructura y realizar pruebas de resistencia.	75% de cobertura con redes redundantes y optimización.
6	Ajuste final de la infraestructura y validación completa de la alta disponibilidad.	90% de cobertura con infraestructura de red redundante instalada.

RIESGO 12: INCUMPLIMIENTO DE NORMATIVAS LEGALES.

Plan de Mitigación:

- Realizar auditorías legales internas y externas.
- Auditorías regulares y seguimiento a las normativas.

Meta de Cumplimiento:

Alcanzar el 90% de cobertura en los primeros 6 meses.

Actividades:

Para mitigar el riesgo de incumplimiento de normativas legales, implementaremos un plan que incluye auditorías legales regulares tanto internas como externas. Durante los primeros tres meses, nos enfocaremos en evaluar las normativas legales actuales y el nivel de cumplimiento en la organización (30% de avance). En los meses 3-4, realizaremos auditorías internas y seguimiento de normativas específicas (50% de avance). En los últimos meses, llevaremos a cabo auditorías externas y reforzaremos el cumplimiento con las normativas, alcanzando el 90% de cobertura. Esto garantizará que el banco cumpla con las normativas legales y se eviten multas y sanciones regulatorias.

Tabla de actividades

Mes	Acción puntual	Resultado esperado
1	Evaluar las normativas legales aplicables y el nivel de cumplimiento interno.	Informe de evaluación de cumplimiento normativo.
2	Desarrollar un plan para las auditorías internas y externas.	Plan de auditorías y cronograma definido.
3	Realizar auditorías internas de cumplimiento normativo.	30% de la auditoría interna completada.
4	Realizar auditorías externas y revisión de los informes de cumplimiento.	50% de auditorías externas realizadas y evaluadas.
5	Reforzar las políticas y capacitar al personal sobre las normativas legales.	75% de cumplimiento con las auditorías y capacitación.
6	Validación final de cumplimiento y ajustes en las políticas internas.	90% de cobertura en el cumplimiento normativo.

5. NIVEL DE RIESGO ACTUAL

Gráficamente, el nivel de riesgo se distribuye así:

- Riesgos en nivel **alto (rojo)**: un total de 0
- Riesgos en nivel **medio (amarillo)**: un total de 7
- Riesgos en nivel **aceptable (verde)**: un total de 5

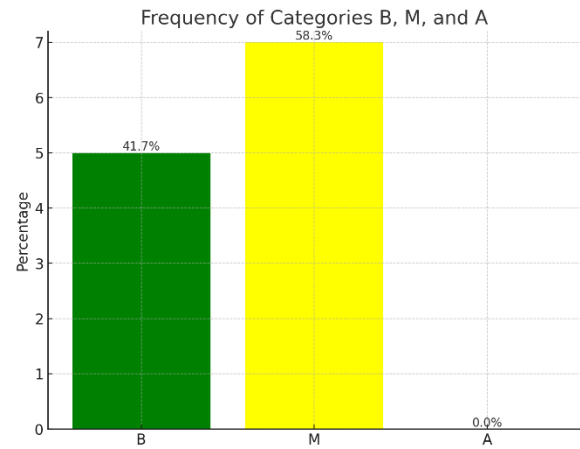


Ilustración 1. RIESGO.

La exposición de la institución actualmente se considera **Media** debido a la naturaleza de los activos que se manejan (banca electrónica, información financiera, datos personales).

6. SOLICITUDES AL DIRECTORIO

Se solicita al Directorio, liderado por el Ing. Zhuma, la aprobación para implementar los planes de mitigación propuestos en este informe, incluyendo la autenticación multifactor (MFA), el monitoreo continuo de accesos, la capacitación y simulacros sobre phishing, y las auditorías de seguridad periódicas. Además, se requiere la asignación de recursos adecuados para la ejecución de estas medidas, con el objetivo de reducir los riesgos asociados con la seguridad de la información en el banco. Estas acciones son fundamentales para garantizar la protección de los activos más críticos y asegurar el cumplimiento con normativas internacionales.

7. CONCLUSIÓN

En conclusión, los riesgos de seguridad de la información identificados en el banco son significativos y deben abordarse de manera urgente para evitar consecuencias graves como la pérdida de datos, problemas financieros, y la afectación de la reputación institucional. La implementación de las estrategias de mitigación propuestas, como la autenticación multifactor (MFA), la capacitación continua, y la adopción de protocolos de comunicación seguros, contribuirá significativamente a mejorar la seguridad y a proteger los activos críticos. La estrategia integral de respuesta a los riesgos está diseñada para cubrir todas las áreas clave, permitiendo al banco operar de manera más segura y conforme a las normativas vigentes.

8. RECOMENDACIONES

Se recomienda que el Directorio apruebe la implementación de los planes de mitigación propuestos de manera inmediata para asegurar que el banco no solo cumpla con las normativas legales, sino que también proteja la confianza de los clientes. Es crucial priorizar la ejecución de estas medidas, especialmente aquellas relacionadas con el acceso no autorizado a los sistemas y la protección de datos confidenciales. Asimismo, se recomienda realizar auditorías de seguridad internas y externas de forma regular para asegurar que los sistemas se mantengan seguros a largo plazo. Además, debe establecerse un plan de capacitación continua para los empleados para minimizar los errores humanos y mejorar la respuesta ante incidentes de seguridad.

ID	FECHA DE REGISTRO	RIESGO / EVENTO
ID-001	1/4/2025	Acceso no autorizado a sistemas bancarios móviles
ID-002	1/4/2025	Ataques de phishing dirigidos a usuarios bancarios
ID-003	1/4/2025	Vulnerabilidad en la app móvil
ID-004	1/4/2025	Pérdida de dispositivos móviles con información crítica
ID-005	1/4/2025	Inseguridad en la red de comunicación
ID-006	1/4/2025	Fugas de información por errores humanos
ID-007	1/4/2025	Caídas en el servicio de la app móvil
ID-008	1/4/2025	Errores en la autenticación multifactor
ID-009	1/4/2025	Problemas con la actualización de la aplicación
ID-010	1/4/2025	Sobrecarga de tráfico en la app móvil
ID-011	1/4/2025	Problemas con la conectividad de red
ID-012	1/4/2025	Incumplimiento de normativas legales

Potencial Consecuencia

Pérdida de fondos y datos confidenciales, sanciones legales y pérdida de confianza de los clientes.
Robo de datos sensibles de clientes, pérdidas financieras y daño a la reputación.
Exposición de datos sensibles de clientes, pérdida de integridad de las transacciones.
Acceso no autorizado a cuentas bancarias, robo de datos sensibles.
Exposición de datos bancarios y vulnerabilidad a ataques man-in-the-middle (MITM).
Exposición de información confidencial de clientes debido a errores operativos o negligencia.
Falta de disponibilidad, imposibilidad de realizar transacciones, pérdida de ingresos.
Acceso no autorizado a cuentas de usuarios legítimos, pérdida de fondos.
Pérdida de funcionalidad, errores operativos, inconvenientes para los usuarios.
Desempeño deficiente de la aplicación, interrumpiendo el acceso de los usuarios.
Interrupciones en el servicio, no se pueden realizar operaciones bancarias.
Multas y sanciones regulatorias, afectación a la reputación de la empresa.

Línea de Negocio	Macro Proceso	Proceso
BANCA ELECTRÓNICA	Gestión de Seguridad	Administración de Seguridad de la Información
BANCA ELECTRÓNICA	Gestión de Seguridad	Concientización y Educación al Cliente
BANCA ELECTRÓNICA	Gestión de Tecnología	Seguridad en la Aplicación
BANCA ELECTRÓNICA	Gestión de Seguridad	Protección de Datos
BANCA ELECTRÓNICA	Gestión de Tecnología	Seguridad en la Red
BANCA ELECTRÓNICA	Gestión Operativa	Gestión de Seguridad Interna
BANCA ELECTRÓNICA	Gestión Operativa	Mantenimiento de Infraestructura
BANCA ELECTRÓNICA	Gestión de Seguridad	Administración de Seguridad de la Información
BANCA ELECTRÓNICA	Gestión de Tecnología	Seguridad en la Aplicación
BANCA ELECTRÓNICA	Gestión Operativa	Gestión de Servicios de IT
BANCA ELECTRÓNICA	Gestión de Tecnología	Gestión de Infraestructura
BANCA ELECTRÓNICA	Gestión de Cumplimiento	Cumplimiento Normativo

Subproceso	Tipo de evento	Factor de riesgo
Gestión de Accesos	Tecnológico	Tecnologías de la Información
Capacitación continua	Tecnológico	Tecnologías de la Información
Evaluación de vulnerabilidades	Tecnológico	Tecnologías de la Información
Gestión de dispositivos móviles	Tecnológico	Tecnologías de la Información
Protección de redes de comunicación	Tecnológico	Tecnologías de la Información
Capacitación de Personal	Tecnológico	Tecnologías de la Información
Monitoreo de la Infraestructura	Tecnológico	Tecnologías de la Información
Gestión de Accesos	Tecnológico	Tecnologías de la Información
Implementación de Actualizaciones	Tecnológico	Tecnologías de la Información
Gestión de Tráfico en Línea	Tecnológico	Tecnologías de la Información
Redundancia de Red	Tecnológico	Tecnologías de la Información
Cumplimiento Legal	Tecnológico	Tecnologías de la Información

Fallas o insuficiencias	Subtipo de Riesgo	IMPACTO		
		C	I	D
Incumplimiento de normativa	Tecnológico	1	1	1
Falta de educación continua en seguridad	Tecnológico	2	2	1
No realización de pruebas de penetración regulares	Tecnológico	2	3	1
Falta de control de seguridad en dispositivos personales	Tecnológico	1	1	2
Uso de protocolos inseguros (HTTP en vez de HTTPS)	Tecnológico	2	2	3
Falta de un plan de capacitación continua	Tecnológico	2	1	1
Servidores no escalables o configurados adecuadamente	Tecnológico	2	1	2
Fallos en el proceso de verificación de MFA	Tecnológico	3	2	1
Parches de software no instalados a tiempo	Tecnológico	1	1	1
Capacidad insuficiente para manejar altos volúmenes de tráfico	Tecnológico	2	1	3
No existe redundancia en las conexiones de red	Tecnológico	2	1	2
Falta de auditorías regulares de cumplimiento	Tecnológico	1	3	1

CTO inicial IMP	PROBABILIDAD DE OCURRENCIA inicial	RIESGO INHERENTE inicial
B	M	2
M	M	3
M	M	3
B	M	2
M	M	3
B	M	2
M	M	3
M	M	3
B	M	2
M	M	3
M	M	3
B	M	2

CONTROLES existentes	EFFECTIVIDAD	PROMEDIO
Restricción de acceso a la plataforma móvil, solo para administradores.	1	1
Campañas periódicas de concientización sobre phishing.	2	2
Parches regulares en el código de la app.	2	2
Cifrado de dispositivos móviles.	1	1
Implementación de HTTPS y cifrado SSL.	2	2
Programas de formación y auditorías internas periódicas.	1	1
Servicios de cloud computing escalables.	2	2
Revisión de sistemas MFA.	1	1
Parches regulares y pruebas de compatibilidad en todas las versiones.	2	2
Optimización de los servidores y balanceo de carga.	2	2
Establecer redes redundantes y mejorar las conexiones.	3	3
Auditorías regulares y seguimiento a las normativas.	2	2

RIESGO NETO O RESIDUAL INICIAL	TRATAMIENTO / RESPUESTA
2	Mitigar
1.5	Tratar
1.5	Tratar
2	Mitigar
1.5	Tratar
2	Mitigar
1.5	Tratar
3	Mitigar
1	Tratar
1.5	Mitigar
1	Mitigar
1	Mitigar

Planes de mitigación	Fecha Final
Implementar MFA y monitoreo continuo de accesos y actividades sospechosas.	1/10/2025
Mejorar programas de capacitación y simulacros de phishing.	1/10/2025
Implementar pruebas de penetración continuas y auditorías.	1/10/2025
Implementar políticas de gestión de dispositivos móviles y bloqueo remoto.	1/10/2025
Reforzar la seguridad de la red e implementar protocolos seguros de comunicación.	1/10/2025
Implementar formación continua y auditorías internas.	1/10/2025
Implementar infraestructura en la nube y pruebas de resiliencia.	1/10/2025
Reforzar y revisar el proceso de autenticación multifactor.	1/10/2025
Implementar sistema de gestión de parches y versiones.	1/10/2025
Invertir en optimización de red y escalabilidad.	1/10/2025
Invertir en infraestructura de red de alta disponibilidad.	1/10/2025
Realizar auditorías legales internas y externas.	1/10/2025

PRESUPUESTO (cuando aplique)	LIMITACIONES / SUPUESTOS
\$50,000.00	Ninguna
\$5,000.00	Recursos limitados
\$20,000.00	Requiere tiempo de desarrollo
\$30,000.00	Costos adicionales por implementación
\$25,000.00	Capacitación continua
\$5,000.00	Disponibilidad del personal
\$40,000.00	Costo de infraestructura
\$15,000.00	Limitaciones tecnológicas
\$10,000.00	Requiere tiempo de desarrollo
\$50,000.00	Restricciones presupuestarias
\$60,000.00	Costos de infraestructura
\$20,000.00	Requiere aprobación legal

RESPONSABLE (¿Quién?)	Grado de Cumplimiento del plan	RIESGO NETO O RESIDUAL FINAL
Gerencia de TI	80% en los 6 primeros meses	2
Gerencia de Seguridad	75% en los 3 primeros meses	1.5
Gerencia de Tecnología	85% en los 6 primeros meses	1.5
Gerencia de Seguridad	90% en los 6 primeros meses	2
Gerencia de Tecnología	95% en los 6 primeros meses	1.5
Recursos Humanos	85% en los 3 primeros meses	2
Gerencia de Tecnología	90% en los 6 primeros meses	1.5
Gerencia de TI	90% en los 6 primeros meses	3
Gerencia de Tecnología	80% en los 6 primeros meses	1
Gerencia de Tecnología	85% en los 3 primeros meses	1.5
Gerencia de TI	90% en los 3 primeros meses	1
Gerencia de Cumplimiento	90% en los 6 primeros meses	1

COMENTARIOS / OBSERVACIONES

ISO 27001 A.9.1.2 / A.9.4.1
LOPDP Art. 39
ISO 27001 A.12.6.1
LOPDP Art. 7
ISO 27001 A.13.1
LOPDP Art. 7
ISO 27001 A.17.2.1
ISO 27001 A.9.4.2
ISO 27001 A.12.6.1
ISO 27001 A.17.1.3
ISO 27001 A.13.1
LOPDP, SB Res. 208-2018